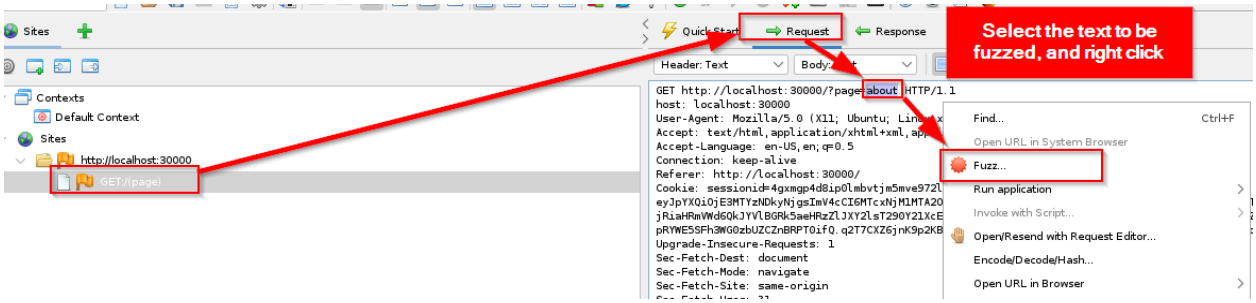
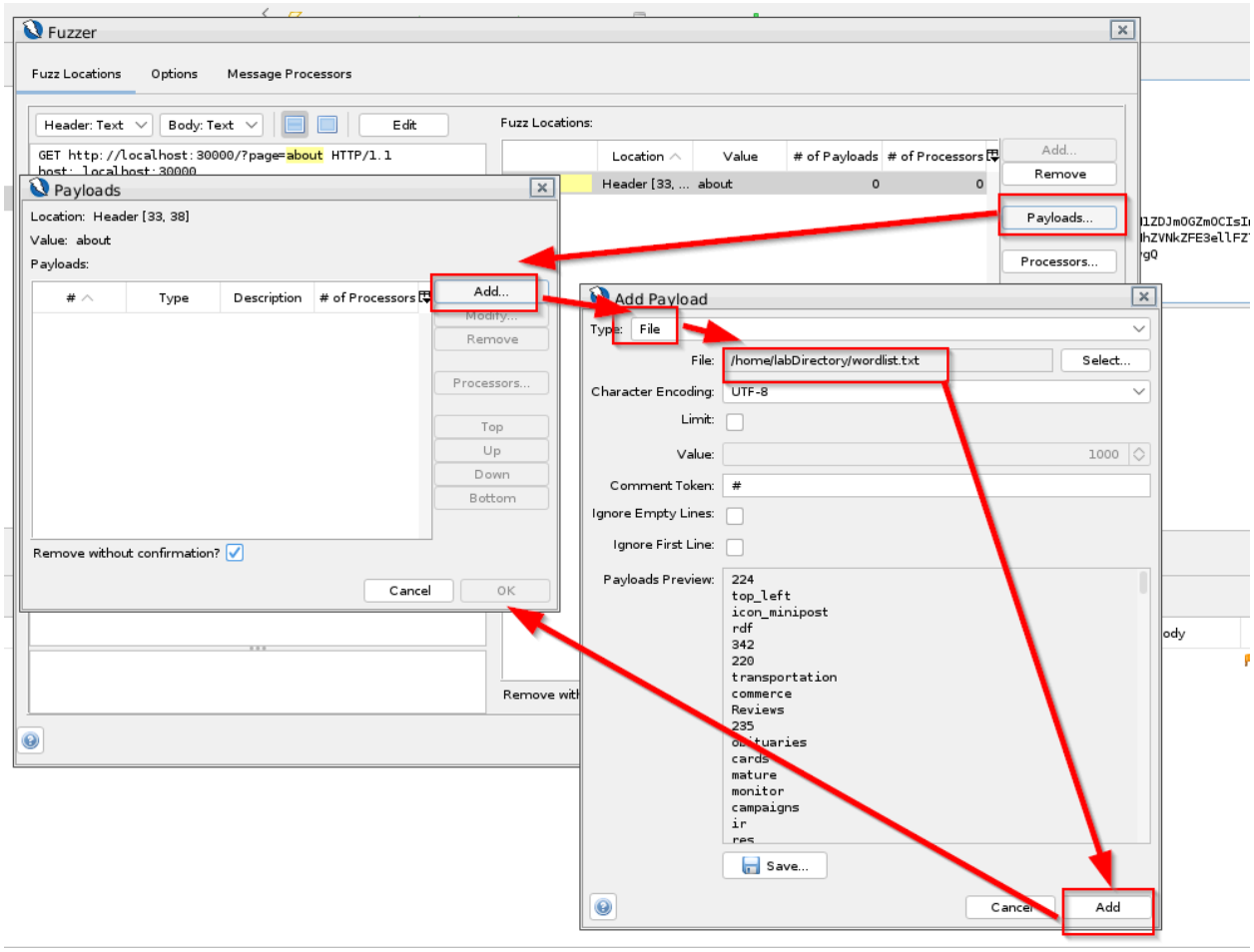
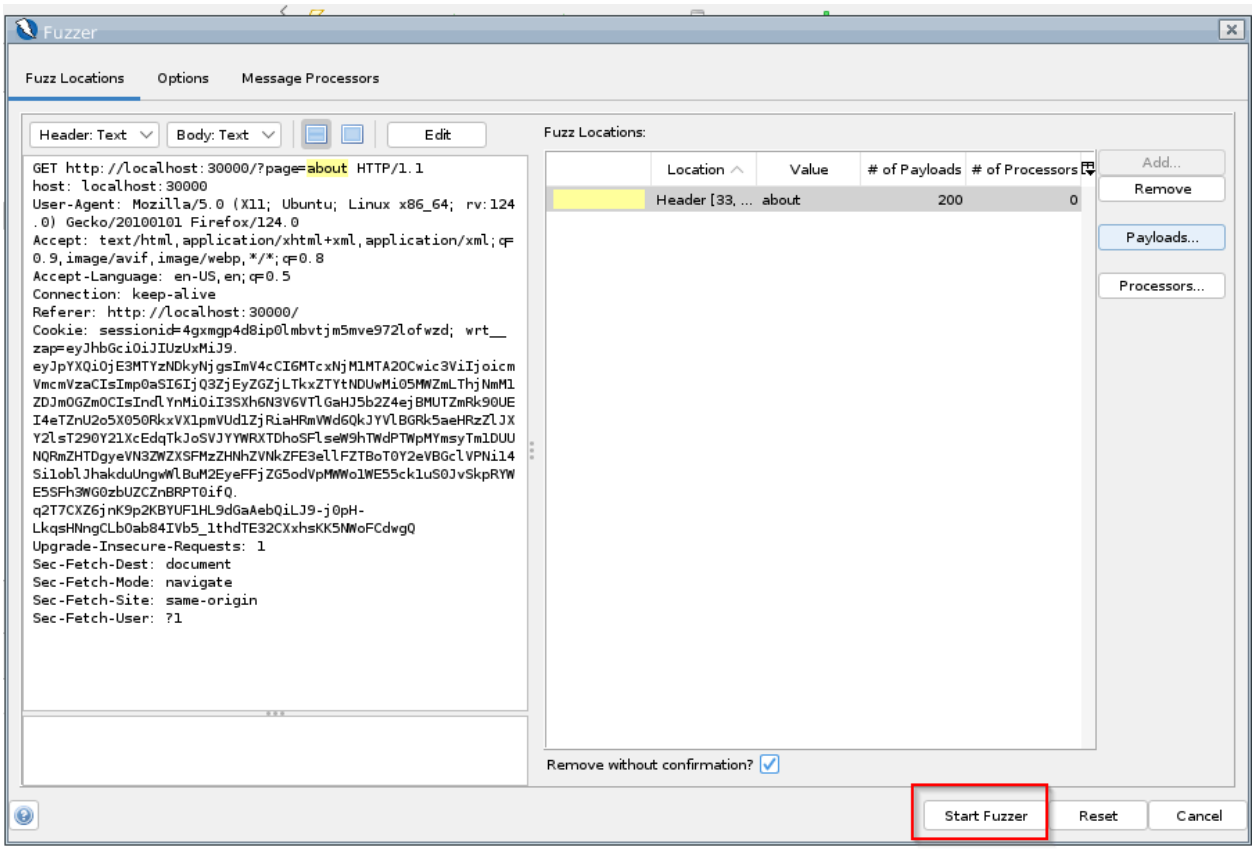
FUZZING through ZAP

NOTE: The figures below are based on URL http://localhost:30000. But the right URL in our context is **http://websec-bodhi.duckdns.org:30000**. The screenshots are from older version of labs, but the concept remains same.

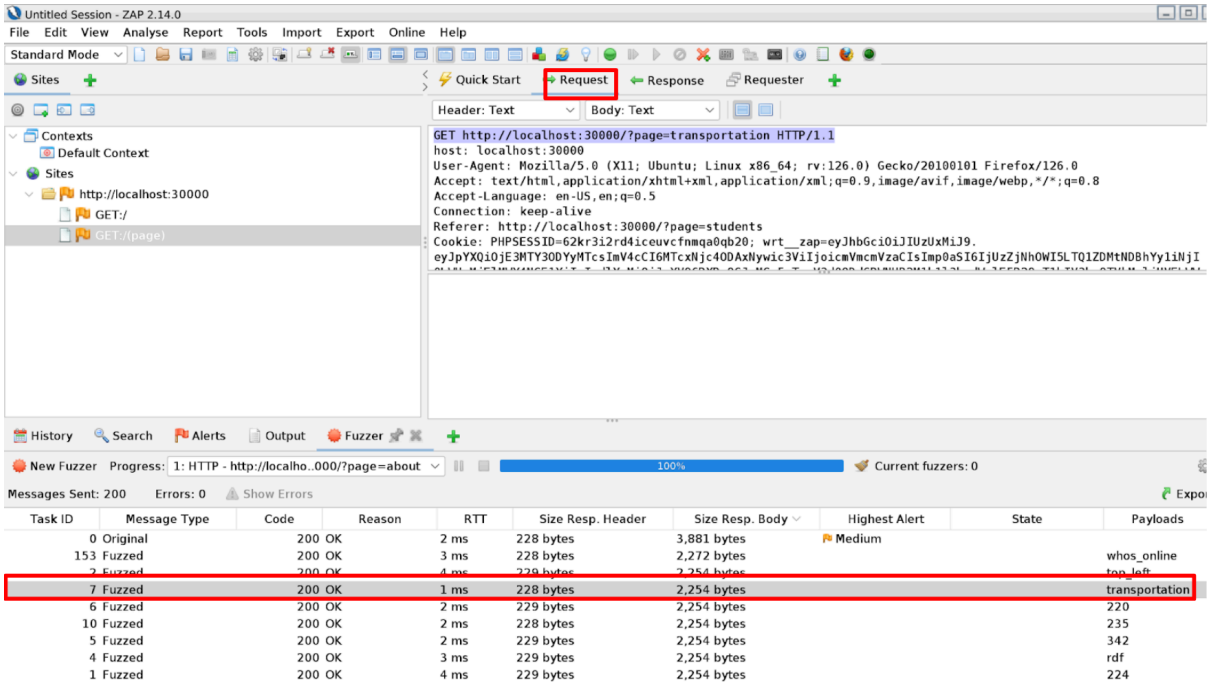
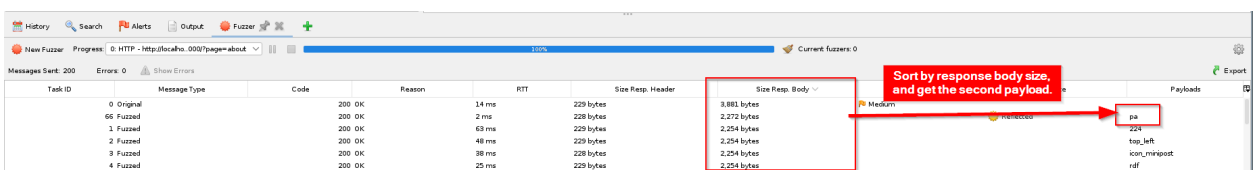
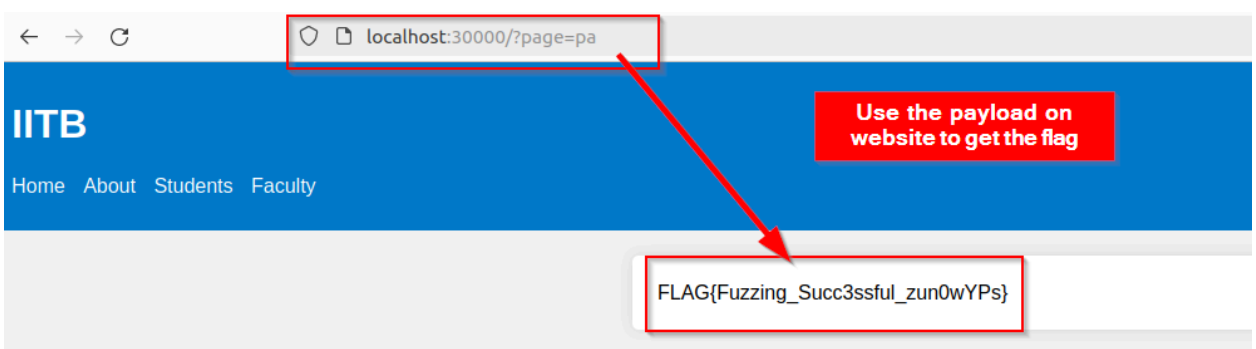
- Ensure FoxyProxy is disabled first. This is important, since without ZAP running, it won't know where to forward traffic
- Then visit http://localhost:30004/zap/ (this can take a few minutes), followed by http://websec-bodhi.duckdns.org:30000
- Then in ZAP, ensure HUD is disabled and also enable FoxyProxy now with the right pattern to forward the traffic of **http://websec-bodhi.duckdns.org:30000** to ZAP (as covered in activity 1)
- Now navigate through the website **http://websec-bodhi.duckdns.org:30000** so that it appears under Sites.
- Identify the GET request that deals with page GET:/(page). Then follow the below screens. We are essentially feeding a wordlist, where in




Fuzzer
Fuzz Locations
Options
Message Processors
Header: Text
Body: Text
Edit
Fuzz Locations:
GET http://localhost:30000/?page=about HTTP/1.1
host: localhost:30000
Location
Value
# of Payloads
# of Processors
Header [33, ...
about
0
0
Add...
Remove
Payloads...
Processors...
Payloads
Location: Header [33, 38]
Value: about
Payloads:
#
Type
Description
# of Processors
Add...
Modify...
Remove
Processors...
Top
Up
Down
Bottom
Remove without confirmation?
Cancel
OK
Add Payload
Type: File
File: /home/labDirectory/wordlist.txt
Select...
Character Encoding: UTF-8
Limit:
Value: 1000
Comment Token: #
Ignore Empty Lines:
Ignore First Line:
Payloads Preview:
224
top_left
icon_minipost
rdf
342
220
transportation
commerce
Reviews
235
obituaries
cards
mature
monitor
campaigns
ir
res
Save...
Cancel
Add



- Post this, you will see a lot of requests made by ZAP of the type “GET **http://websec-bodhi.duckdns.org:30000/**?page=xxx HTTP/1.1” (where xxx is taken from the word list). You can select any request and see what was sent under “Request” in the top window.



- Now to see if any hidden page is there, we need to check if there is any difference in response across all payloads. So, let us sort based on response size. See below . Once you obtain the right URL which is hidden, visit it via browser to get the flag! Submit the flab in the cLab app.